



Nombre:Luis Alberto Vargas Gonzalez

Fecha:28/04/2026

Actividad y unidad:U8 AI. Presentación Ejecutiva de Proyecto Integrador

Clase: Planes , Programas y Procedimientos de Seguridad.

Maestría en Ciberseguridad.

Introducción

En el actual ecosistema digital, la industria automotriz ha dejado de ser meramente mecánica para convertirse en un sector impulsado por el software, la interconectividad y la innovación constante. La organización objeto de este estudio, una empresa global de desarrollo de hardware y software con una fuerza laboral de 35,000 empleados y un centro de diseño estratégico en Múnich, se enfrenta a un desafío crítico: proteger su propiedad intelectual y asegurar la continuidad de su producción en un entorno de amenazas cada vez más sofisticadas.

El presente Proyecto Integrador surge como una respuesta técnica y administrativa ante las brechas de seguridad detectadas inicialmente, tales como la obsolescencia de la infraestructura de red, la falta de control sobre activos de software y una cultura organizacional marcada por la apatía hacia los riesgos digitales. A través de la consolidación de ocho avances estratégicos, este documento detalla un plan integral que abarca desde la identificación de activos y la creación de políticas de uso aceptable, hasta la implementación de marcos de gobernanza internacionales como ISO 27001, COBIT y NIST. El objetivo primordial no es solo blindar la infraestructura tecnológica, sino alinear la ciberseguridad con los objetivos de negocio para garantizar la resiliencia y la competitividad de la firma a nivel mundial.

AVANCE DE PROYECTO INTEGRADOR

Detección de problemáticas

**Nombre del
alumno:**

Luis Alberto Vargas Gonzalez

I. Servicios de seguridad con los que cuenta la empresa

A pesar de las grandes deficiencias, la empresa implementa los siguientes mecanismos básicos:

Control de Acceso Físico por Proximidad: La empresa utiliza un sistema de gafetes de proximidad para regular la entrada de los empleados a las oficinas.

Vigilancia por Circuito Cerrado (CCTV): Se cuenta con cámaras de seguridad instaladas en las instalaciones, diseñadas para el monitoreo de los espacios físicos. Sin embargo, el caso menciona que la mayoría de estas no se encuentran operativas.

Protección de Endpoints (Antivirus): Existe un servicio de protección para los 10,000 equipos que utilizan el sistema operativo Windows, el cual consiste en la implementación de un antivirus de versión gratuita.

II. Integridad de la información

La empresa presenta una gestión de la integridad sumamente deficiente, caracterizada por la ausencia total de controles que validen la exactitud y consistencia de los datos. Los puntos clave que comprometen la integridad son:

Ausencia de Control de Acceso Lógico: No existen jerarquías de acceso ni roles definidos. Al tener todos los empleados "full access", cualquier usuario puede modificar o eliminar información crítica sin restricciones en todos los sistemas.

Falta de Trazabilidad y Auditoría: No existe un historial de cambios ni registros de mantenimiento para los equipos. Esto imposibilita identificar quién realizó una modificación, cuándo se hizo o si el cambio fue autorizado.

Instalación de Software No Controlada: Los empleados pueden instalar cualquier tipo de software desde internet sin solicitar permiso. Esto abre la puerta a que malware o aplicaciones maliciosas alteren archivos del sistema o bases de datos sin detección previa.

Inexistencia de Clasificación de Datos: Al no haber un control ni clasificación de la información, no se pueden aplicar reglas de protección específicas para asegurar que los datos más sensibles permanezcan inalterados.

III. Disponibilidad de la información

La disponibilidad de la información en esta organización se encuentra en un estado crítico, ya que diversos factores estructurales y operativos impiden asegurar que los datos y sistemas estén accesibles cuando se requieren:

Ventanas de mantenimiento excesivas e ineficientes: Los servidores requieren procesos de mantenimiento que duran más de 8 horas y pueden prolongarse por más de 2 días. Además, estos procedimientos se realizan con una frecuencia de cada 2 semanas, lo que genera interrupciones constantes en la operación.

Capacidad de respaldo insuficiente: No existe un control formal de respaldos y, ante la falta de espacio en el almacenamiento de los servidores, solo es posible respaldar una cuarta parte de la información. Esto deja al 75% de los datos en riesgo de pérdida total ante un fallo.

Infraestructura de red obsoleta: Los equipos Cisco que operan la red tienen más de 5 años sin actualizaciones, lo que aumenta significativamente la probabilidad de fallas de hardware sin posibilidad de soporte técnico inmediato.

Carencia de acceso remoto seguro: La empresa no cuenta con un proveedor de comunicaciones que ofrezca servicios de VPN, impidiendo que los empleados se conecten a los sistemas de manera remota.

Riesgos físicos y falta de planeación: El centro de diseño, ubicado en una zona sísmica, carece de un plan de evacuación claro. Sumado a esto, no existe un inventario de activos ni un control de mantenimiento preventivo, por lo que los equipos solo se cambian en situaciones de emergencia.

IV. Nivel de la confiabilidad de la información

El nivel de confiabilidad de la información en la empresa es **extremadamente bajo**, ya que no existe ninguna garantía de que los datos sean auténticos, precisos o que provengan de fuentes seguras. Esta falta de confianza se fundamenta en los siguientes puntos:

Inexistencia de un Inventario de Activos y Control de Cambios: Al no haber un registro oficial de hardware ni un historial de modificaciones, es imposible asegurar la legitimidad de los equipos conectados. Como se nota, esto facilita la sustracción de componentes internos y la introducción de dispositivos ajenos infectados con spyware o adware sin que la organización lo note.

Obsolescencia y Falta de Parches: Los motores de bases de datos (DB2, Oracle y SQL Server) operan con versiones de hace 3 años sin haber recibido parches de seguridad. Una base de datos vulnerable no es confiable, pues la información contenida puede haber sido comprometida o alterada por atacantes explotando fallos conocidos.

Uso de Software No Autorizado: La política que permite a los empleados instalar cualquier software de internet sin permiso degrada la confiabilidad de los equipos de cómputo. Esto introduce un riesgo constante de que herramientas de terceros intercepten o manipulen la información del negocio.

Falta de Gestión de Vulnerabilidades: Al no existir un proceso para actualizar los sistemas operativos y depender de un antivirus gratuito en Windows, la integridad de la plataforma donde reside la información está en duda permanente.

Ausencia de Políticas de Seguridad: Sin un marco normativo o políticas implementadas, la confiabilidad de los procesos depende únicamente de la buena voluntad del empleado, lo cual es inaceptable en un entorno de desarrollo premium.

V. Riesgos y vulnerabilidades

En esta sección se detallan las debilidades del sistema (vulnerabilidades) y los eventos negativos potenciales (riesgos) que podrían afectar a la organización:

Vulnerabilidades Identificadas:

Tecnológicas: Uso de antivirus gratuito en Windows, motores de bases de datos y sistemas operativos sin parches de seguridad desde hace 3 años, y equipo de red Cisco obsoleto sin actualizaciones en 5 años.

Administrativas: Inexistencia de un inventario de activos, falta de control de cambios, ausencia de políticas de seguridad y falta de una administración centralizada de licencias.

Lógicas: Ausencia de roles y jerarquías (acceso total para todos los empleados) y falta de una conexión segura (VPN) para el trabajo remoto.

Físicas: Cámaras de seguridad inoperativas y falta de un plan de evacuación ante sismos en el centro de diseño.

Operativas: Capacidad de respaldo limitada a solo una cuarta parte de la información y ventanas de mantenimiento excesivamente largas.

Riesgos Asociados:

Fuga o Sustracción de Activos: Debido a la falta de inventario y control de mantenimiento, existe el riesgo de robo de componentes internos de los equipos o la pérdida física de dispositivos completos sin que la empresa lo detecte oportunamente.

Compromiso por Software Malicioso: La libre instalación de software de internet y el uso de antivirus básicos facilitan la entrada de spyware, adware o ransomware.

Exfiltración de Propiedad Intelectual: Al no haber roles ni control de invitados, empleados o personas ajenas pueden acceder y copiar diseños de tecnología automotriz premium.

Interrupción Prolongada del Negocio: Los mantenimientos de hasta 2 días y la red obsoleta representan un riesgo de caída total de la producción y el desarrollo.

Pérdida Irreversible de Datos: Ante un fallo crítico de almacenamiento, el 75% de la información no cuenta con respaldo, lo que podría significar la pérdida de años de investigación y desarrollo.

Introducción de Equipos Infectados: La falta de un historial de cambios permite que dispositivos ajenos a la organización sean conectados a la red interna, propagando amenazas de forma lateral.

VI. Posturas de seguridad

En este apartado se describe la actitud actual de la organización frente al riesgo y se proponen las posturas necesarias para alcanzar un nivel de protección adecuado para una empresa de su categoría.

Postura de Seguridad Actual:

- **Postura Reactiva y Negligente:** La empresa solo actúa ante emergencias críticas, como cuando un equipo está a punto de dejar de funcionar. No existe un enfoque preventivo; se ignoran las actualizaciones de bases de datos por 3 años y del equipo de red por 5 años.
- **Postura Permisiva (Abierta):** Existe una política de "puertas abiertas" tanto digital como física. No hay jerarquías de acceso (todos tienen *full access*), no hay políticas de seguridad implementadas, y se permite a los empleados instalar cualquier software sin supervisión.
- **Postura de Desinterés en el Cumplimiento:** No existe un inventario de activos, control de licencias o historial de cambios. Además, se opera con herramientas insuficientes como antivirus gratuitos para una fuerza laboral de 10,000 usuarios de Windows.

Posturas de Seguridad que harían falta:

- **Postura Proactiva y de Prevención:** Es urgente implementar un programa de gestión de parches y actualizaciones periódicas para cerrar las brechas de seguridad en sistemas operativos y motores de bases de datos.
- **Postura de "Menor Privilegio":** Se debe transitar de un modelo de "acceso total" a uno basado en roles (RBAC), donde cada empleado tenga acceso únicamente a la información necesaria para sus funciones.
- **Postura de Cumplimiento y Gobierno (Normativa):** Es indispensable crear y aplicar políticas de seguridad formales, llevar un inventario riguroso de activos y establecer controles de mantenimiento preventivo.
- **Postura de Resiliencia y Continuidad:** La empresa necesita un Plan de Recuperación ante Desastres (DRP) que incluya una estrategia de respaldos completa y un plan de evacuación funcional para el centro de diseño en zona sísmica.
- **Postura Defensiva Robusta:** Sustituir soluciones gratuitas por herramientas de seguridad de grado empresarial (EDR/XDR) y establecer conexiones seguras mediante VPN para el acceso remoto.

AVANCE DE PROYECTO INTEGRADOR

Creación de Políticas de Seguridad

Nombre del alumno:	Luis Alberto Vargas Gonzalez
--------------------	------------------------------

I. Políticas de seguridad de software

1. Política de Protección de Endpoints (Antivirus Corporativo)

- **Alcance:** Todos los equipos de cómputo (estaciones de trabajo y laptops) que utilicen el sistema operativo Windows dentro de la red corporativa y plantas ensambladoras.
- **Descripción:** Queda estrictamente prohibido el uso de versiones de antivirus gratuitas o domésticas. El departamento de TI debe instalar y mantener una solución de antivirus de grado empresarial (EDR) en el 100% de los equipos para garantizar la detección proactiva de amenazas.
- **Relación con vulnerabilidad:** Sustituye el antivirus gratuito actual que no ofrece protección suficiente para una empresa de este nivel.

2. Política de Gestión de Actualizaciones de Sistemas Operativos

- **Alcance:** Todos los 15,000 equipos personales (Windows y macOS) asignados a los empleados en las plantas y el centro de diseño.
- **Descripción:** Se establece un calendario obligatorio de actualizaciones mensuales. Los sistemas operativos deben configurarse para descargar e instalar parches críticos de seguridad de forma automática en un periodo no mayor a 7 días tras su liberación.
- **Relación con vulnerabilidad:** Resuelve la falta de un proceso para que los empleados mantengan actualizados sus sistemas.



3. Política de Mantenimiento y Parches de Bases de Datos

- **Alcance:** Todos los motores de bases de datos (DB2, Oracle y SQL Server) que operan en los sites de la empresa.
- **Descripción:** Todo motor de base de datos debe contar con soporte vigente del fabricante y estar actualizado a una versión no mayor a 12 meses de antigüedad. Es obligatorio aplicar parches de seguridad trimestralmente para mitigar riesgos de inyección o fuga de datos.
- **Relación con vulnerabilidad:** Atiende el rezago de 3 años sin actualizaciones ni parches en las bases de datos críticas.

4. Política de Control de Instalación de Software de Terceros

- **Alcance:** Toda la plantilla de empleados con acceso a equipos informáticos de la organización.
- **Descripción:** Los empleados tienen prohibido descargar o instalar cualquier tipo de software proveniente de internet sin la autorización previa y revisión de seguridad del departamento de TI. El acceso administrativo a los equipos se limitará para evitar instalaciones no autorizadas.
- **Relación con vulnerabilidad:** Mitiga el riesgo de introducir *malware* o *adware* por la instalación libre de software de internet.

5. Política de Gestión y Auditoría de Licencias de Software

- **Alcance:** Departamento de TI y área de Compras.
- **Descripción:** Se debe implementar un sistema de Gestión de Activos de Software (SAM) para rastrear la compra, asignación y vigencia de todas las licencias. Queda prohibida la compra "a granel" sin un control individualizado de derechos de uso por equipo.
- **Relación con vulnerabilidad:** Corrige la falta de administración de licencias compradas a granel y asegura el cumplimiento legal de la empresa.



II. Políticas de seguridad de hardware

6. Política de Ciclo de Vida y Actualización de Infraestructura de Red

- **Alcance:** Todos los equipos de comunicaciones (routers, switches y firewalls Cisco) en las tres plantas y el centro de diseño.
- **Descripción:** Se establece que ningún equipo de red podrá operar con una antigüedad mayor a 5 años sin un plan de renovación vigente. Es obligatorio que el equipo de TI realice actualizaciones de firmware y parches de seguridad de manera semestral para asegurar el soporte del fabricante.
- **Relación con vulnerabilidad:** Ataca directamente la obsolescencia de 5 años del equipo Cisco y la falta de actualizaciones que comprometen la estabilidad de la red.

7. Política de Mantenimiento Preventivo de Servidores y Mainframes

- **Alcance:** Los 30 servidores Windows, 15 Unix (AIX) y los 3 mainframes de la organización.
- **Descripción:** El departamento de TI debe programar ventanas de mantenimiento preventivo mensual que no excedan las 4 horas de inactividad. Se prohíben los mantenimientos prolongados de 2 días que afecten la disponibilidad, debiendo implementar esquemas de alta disponibilidad para evitar cortes en el servicio.
- **Relación con vulnerabilidad:** Reduce los tiempos excesivos de mantenimiento (de 8 horas a 2 días) y mejora la disponibilidad operativa de los sites.



8. Política de Inventario y Control de Activos Informáticos

- **Alcance:** Todo el hardware propiedad de la empresa, incluyendo servidores, estaciones de trabajo y periféricos.
- **Descripción:** Se debe mantener un inventario digitalizado y actualizado en tiempo real de todos los activos, incluyendo número de serie, ubicación, usuario asignado e historial de cambios. Queda prohibida la conexión a la red de cualquier equipo que no esté debidamente etiquetado y registrado en el inventario oficial.
- **Relación con vulnerabilidad:** Resuelve la inexistencia de un inventario de activos y el nulo control de cambios o mantenimiento.

9. Política de Sustitución y Renovación Tecnológica

- **Alcance:** Equipos de cómputo personales (10,000 Windows y 5,000 macOS) y servidores.
- **Descripción:** La sustitución de equipos se realizará con base en su ciclo de vida útil (máximo 4 años para laptops y 5 para servidores) y no únicamente en situaciones de emergencia. Cada cambio debe quedar documentado en el historial de mantenimiento del activo.
- **Relación con vulnerabilidad:** Elimina la mala práctica de cambiar equipos solo en caso de emergencia, lo que pone en riesgo la productividad del empleado.

10. Política de Integridad Física de los Equipos de Cómputo

- **Alcance:** Todo el personal que tenga asignado un equipo informático o acceso a los sites.
- **Descripción:** Queda estrictamente prohibida la apertura, modificación física o sustracción de componentes internos de los equipos sin la supervisión del área de TI. Cualquier reparación o cambio de hardware debe registrarse en una bitácora de mantenimiento centralizada para evitar la introducción de dispositivos infectados o la pérdida de partes.
- **Relación con vulnerabilidad:** Como bien se comentó antes, esta política previene la sustracción de partes y la introducción de hardware ajeno infectado ante la falta de controles actuales.



III. Políticas de información confidencial

11. Política de Control de Acceso Basado en Roles (RBAC)

- **Alcance:** Todos los sistemas informáticos, bases de datos y aplicaciones de la empresa.
- **Descripción:** Se elimina el acceso total (*full access*) generalizado. El acceso a la información se otorgará bajo el "principio de menor privilegio", donde cada empleado tendrá permisos exclusivamente para los datos necesarios según su función laboral, previa autorización del jefe de área.
- **Relación con vulnerabilidad:** Mitiga el riesgo de que cualquier empleado modifique o elimine información crítica de manera no autorizada.

12. Política de Clasificación de la Información

- **Alcance:** Toda la información generada, procesada o almacenada por la organización, incluyendo diseños automotrices y datos multimedia.
- **Descripción:** Se establecen cuatro niveles de clasificación: Pública, Uso Interno, Confidencial y Restringida. Toda la información debe ser etiquetada según su sensibilidad y solo los niveles "Confidencial" y "Restringida" requerirán controles de cifrado y auditoría estricta.
- **Relación con vulnerabilidad:** Resuelve la falta total de clasificación y control de datos mencionada en el caso.



13. Política de Seguridad para el Acceso Remoto (VPN)

- **Alcance:** Empleados que requieran conexión a los sistemas desde fuera de las instalaciones físicas.
- **Descripción:** Es obligatorio el uso de una red privada virtual (VPN) con cifrado de grado industrial y autenticación de dos factores (2FA) para cualquier conexión remota. Se prohíbe el uso de conexiones directas o protocolos no cifrados hacia la red interna.
- **Relación con vulnerabilidad:** Cubre la carencia de un proveedor de servicios de VPN y la falta de métodos de conexión remota seguros.

14. Política de Cifrado y Protección de Bases de Datos

- **Alcance:** Motores de bases de datos DB2, Oracle y SQL Server en todos los sites.
- **Descripción:** Toda información sensible, especialmente la propiedad intelectual del centro de diseño, debe estar cifrada tanto en reposo (dentro de la base de datos) como en tránsito (en la red). Se deben implementar mecanismos de integridad para asegurar que los registros no sean alterados sin dejar rastro.
- **Relación con vulnerabilidad:** Protege los datos críticos almacenados en bases de datos que actualmente no reciben parches de seguridad ni tienen controles de integridad.

15. Política de Respaldos de Información Crítica

- **Alcance:** Servidores, mainframes y bases de datos que contienen información vital para la manufactura y el diseño.
- **Descripción:** La empresa debe garantizar el respaldo del 100% de la información crítica de manera diaria. Se debe implementar un esquema de almacenamiento que asegure que siempre haya espacio suficiente para los respaldos y que existan copias fuera de sitio (*off-site*) para recuperación en caso de desastre.
- **Relación con vulnerabilidad:** Corrige la deficiencia actual donde solo se puede respaldar una cuarta parte de la información por falta de espacio.



IV. Políticas ambientales

16. Política de Respuesta ante Sismos y Desastres Naturales

- **Alcance:** Todo el personal y visitantes del centro de diseño ubicado en Múnich.
- **Descripción:** Es obligatorio establecer un Plan de Continuidad del Negocio (BCP) que incluya rutas de evacuación señalizadas, puntos de reunión seguros y la realización de simulacros trimestrales para asegurar la integridad física de los empleados en zonas de alto riesgo sísmico.
- **Relación con vulnerabilidad:** Mitiga el riesgo de fatalidades y pérdida de personal ante la falta de un plan claro de evacuación en el centro de diseño.

17. Política de Vigilancia y Monitoreo Físico (CCTV)

- **Alcance:** Todas las áreas comunes, entradas, salidas y perímetros de las plantas ensambladoras y oficinas administrativas.
- **Descripción:** El departamento de Seguridad Física debe asegurar que el 100% de las cámaras de seguridad estén operativas y graben de forma continua. Se debe realizar una revisión técnica quincenal para garantizar que no existan puntos ciegos o cámaras dañadas.
- **Relación con vulnerabilidad:** Corrige la inoperatividad de las cámaras actuales que favorece el ingreso de personas no autorizadas.



18. Política de Gestión de Residuos de Manufactura y Electrónicos

- **Alcance:** Áreas de producción, laboratorios de hardware y oficinas administrativas.
- **Descripción:** Se debe implementar un programa de clasificación y disposición final de desechos generados en la manufactura automotriz. Los residuos electrónicos (hardware obsoleto) deben ser destruidos o reciclados mediante proveedores certificados para evitar la fuga de información sensible contenida en componentes físicos.
- **Relación con vulnerabilidad:** Resuelve la falta de control de desechos generados por el proceso de manufactura en las oficinas.

19. Política de Seguridad Física en Centros de Datos (Sites)

- **Alcance:** Los tres sites de servidores ubicados en las plantas ensambladoras.
- **Descripción:** El acceso a las salas de servidores y mainframes está restringido únicamente al personal de TI autorizado. Los sistemas de enfriamiento, detección de incendios y suministro de energía ininterrumpida (UPS) deben ser inspeccionados mensualmente para prevenir fallas por factores ambientales.
- **Relación con vulnerabilidad:** Asegura la protección de los mainframes y servidores ante fallas ambientales o accesos físicos indebidos.

20. Política de Protección de Activos en Tránsito y Exterior

- **Alcance:** Equipo de hardware automotriz premium en fase de desarrollo y prototipado.
- **Descripción:** Todo hardware en desarrollo que deba ser trasladado entre plantas debe contar con un registro de custodia y protección contra factores ambientales (humedad, calor extremo). Queda prohibido dejar prototipos o hardware sensible en áreas no resguardadas del centro de diseño.
- **Relación con vulnerabilidad:** Protege el hardware premium y deportivo contra daños ambientales o robos físicos por falta de controles de activos.



V. Políticas de RH

21. Política de Control de Visitantes e Invitados

- **Alcance:** Todas las instalaciones de la empresa, incluyendo las 3 plantas ensambladoras y el centro de diseño.
- **Descripción:** Todo visitante debe registrarse obligatoriamente en la recepción, portar un gafete de identificación visible y estar acompañado por un empleado responsable en todo momento. Queda estrictamente prohibido el ingreso de invitados a áreas críticas como los sites de servidores o laboratorios de desarrollo sin autorización escrita de la gerencia.
- **Relación con vulnerabilidad:** Elimina la práctica actual de permitir invitados sin restricciones debido a la falla en cámaras y falta de control físico.

22. Política de Concientización y Capacitación en Ciberseguridad

- **Alcance:** Los 35,000 empleados de la organización a nivel mundial.
- **Descripción:** Es obligatorio que todo el personal participe en sesiones de capacitación trimestrales sobre seguridad de la información, enfocadas en la detección de malware, ingeniería social y el uso correcto de los sistemas institucionales. La capacitación se evaluará y será requisito para mantener los privilegios de acceso al sistema.
- **Relación con vulnerabilidad:** Ataca la apatía del usuario y el desconocimiento que permite la instalación de software malicioso y el mal manejo de los activos.



23. Política de Uso Aceptable de Activos Tecnológicos

- **Alcance:** Empleados con equipos asignados (Windows y macOS) y personal de desarrollo multimedia (Java e iOS).
- **Descripción:** Los equipos informáticos son propiedad exclusiva de la empresa y deben utilizarse únicamente para fines laborales. El incumplimiento de las políticas de seguridad, como la descarga de software no autorizado, será motivo de sanciones disciplinarias de acuerdo con el reglamento interno de trabajo.
- **Relación con vulnerabilidad:** Establece consecuencias legales y administrativas ante la instalación libre de software de internet sin permiso.

24. Política de Confidencialidad y Acuerdos de No Divulgación (NDA)

- **Alcance:** Todo el personal interno, contratistas y proveedores externos de la empresa.
- **Descripción:** Es requisito indispensable la firma de un acuerdo de confidencialidad al momento de la contratación. Este acuerdo obliga al empleado a proteger los secretos industriales de la tecnología automotriz premium y deportiva, incluso después de terminar su relación laboral con la empresa.
- **Relación con vulnerabilidad:** Protege la propiedad intelectual en un entorno donde no existen jerarquías de acceso ni roles definidos.

25. Política de Revocación de Accesos por Baja de Personal

- **Alcance:** Departamentos de Recursos Humanos y Tecnologías de la Información.
- **Descripción:** Ante la terminación de un contrato laboral, el área de RH debe notificar de inmediato a TI para la revocación total de accesos lógicos (cuentas, correos, VPN) y la recuperación del gafete de proximidad en un plazo no mayor a 2 horas. Se debe realizar una auditoría final del equipo asignado antes de su reingreso al inventario.
- **Relación con vulnerabilidad:** Asegura que los privilegios de "full access" sean eliminados oportunamente para evitar accesos no autorizados post-empleo.



ANÁLISIS FODA		
Luis Alberto Vargas Gonzalez		
INTERNAS	Fortalezas	Debilidades
	1. Marca premium y presencia global sólida. 2. Centros de diseño especializado en Múnich. 3. talento técnico en desarrollo multimedia y mainframes.	1. Infraestructura de red obsoleta (Cisco +5 años). 2. Falta total de roles y jerarquías (Full access). 3. Ventanas de mantenimiento ineficientes (2 días)
EXTERNAS	Oportunidades	Amenazas
	1. Implementación de estándares internacionales (ISO 27001). 2. Automatización de procesos de actualización de software. 3. Fortalecimiento de confianza de cliente mediante seguridad.	1. Ataques de ransomware em bases de datos no parchadas. 2. Actividad sísmica en Múnich y en zona de diseño. 3. Robo de propiedad intelectual por falta de control de invitados a instalaciones.

Matriz RASCI

Luis Alberto Vargas Gonzalez

R: Responsible | A: Accountable | S: Support | C: Consulted | I: Informed.

Actividades	Persona 1: Dirección general (CEO)	Persona 2: Especialista en seguridad	Persona 3: Gerente de TI (IT Manager)	Persona 4: Administrador de sistemas/redes.	Persona 5: Recursos Humanos
Actividad 1: Definición de roles y accesos (RBAC).	I	A	C	R	S
Actividad 2: Renovación de equipo Cisco obsoleto.	I	S	A	R	I

Actividad 3: Plan de recuperación (Sismos en Múnich).	A	C	I	I	R
Actividad 4: Actualización de sistemas de base de datos (DB2/SQL).	I	C	A	R	I
Actividad 5: Capacitación en ciberseguridad.	A	S	I	I	R
Actividad 6: Inventario de equipos informáticos	I	C	A	R	S
Actividad 7: Control de acceso físico y gafetes.	I	C	S	I	R
Actividad 8: Instalación de	I	S	A	R	C

antivirus corporativo					
Actividad 9: Revocación inmediata de accesos (bajas)	I	C	S	R	A
Actividad 10: Gestión de desechos tecnológicos.	I	C	S	R	S

Procedimiento III: Método DELPHI (Consenso de Expertos)

Objetivo: Establecer una prioridad estratégica de remediación para las vulnerabilidades críticas del caso, optimizando el uso de recursos limitados.

1. Formación del Panel de Expertos

Se selecciona un grupo multidisciplinario que entienda tanto el negocio como la tecnología de la empresa:

- **Especialista en Ciberseguridad:** Aporta la visión de riesgos y amenazas.
- **Gerente de TI:** Conoce la capacidad técnica de los 35,000 empleados y la infraestructura actual.
- **Director del Centro de Diseño en Múnich:** Representa los intereses de la propiedad intelectual premium.
- **Responsable de Operaciones en Plantas:** Aporta la visión de la continuidad de la manufactura.

2. Fase de Cuestionarios (Rondas)

El proceso se realiza de forma anónima para evitar sesgos de autoridad:

- **Ronda 1 (Identificación):** Se solicita a cada experto listar los 3 riesgos que consideran más peligrosos. En este caso, los expertos identifican unánimemente el "**Full Access**" y la "**Obsolescencia de Red**" como puntos críticos.
- **Ronda 2 (Evaluación):** Se comparten los resultados de la Ronda 1 de forma resumida. Los expertos reevalúan sus posturas al ver que otros priorizaron la falta de **respaldos (solo 25% de capacidad)** sobre la actualización de bases de datos.
- **Ronda 3 (Consenso):** Se busca el acuerdo final sobre el orden de ejecución de los proyectos de seguridad.

3. Resultados y Toma de Decisiones

Tras las rondas, el panel llega al siguiente consenso de prioridades para la empresa:

1. **Prioridad 1:** Implementación de Roles y Accesos (RBAC) para eliminar el "Full Access".
2. **Prioridad 2:** Renovación de infraestructura de red Cisco y parchado de bases de datos.
3. **Prioridad 3:** Ampliación de la capacidad de almacenamiento para asegurar el 100% de los respaldos.

Organización	Empresa Automotriz		
Área	Tecnologías de la	Actualizado al día	24/03/2026
Responsable	Luis Alberto Vargas Gonzalez		

No	Marca	Modelo	Descripción	Capacidad	Velocidad	Num Serie	Estado	Fecha de asignación	Asignado a
1	Cisco	Catalyst 3860	Switch de Red de Planta	48 Puertos	1 Gbps	SN-NET-001	Obsoleto	15/05/2021	Planta
2	Cisco	ISR 4431	Router de Borde (Core)	3 Gbps	1.2 GHz	SN-RTR-002	Vulnerable	10/06/2021	Ensambladora 1 Centro de Diseño Múnich
3	IBM	z15	Mainframe de Producción	190 Cores	5.2 GHz	SN-MF-991	Activo	20/01/2022	Site Central Planta 2
4	Dell	PowerEdge R740	Servidor Windows (AD)	128 GB RAM	3.2 GHz	SN-SVR-101	Sin Parches	12/03/2022	Site Central Planta 1
5	IBM	Power S922	Servidor Unix (AIX)	256 GB RAM	3.8 G	SN-SVR-201	Activo	15/04/2022	Site Central Planta 3
6	Apple	MacBook Pro 14"	Laptop de Diseño Multimedia	32 GB RAM	M1 Pro	SN-MAC-5001	Activo	02/02/2025	Diseñador Senior (Múnich)
7	Dell	Latitude 5420	Laptop de Administración	16 GB RAM	2.8 GHz	SN-WIN-8001	Activo	10/03/2025	Administrativo Planta 1

8	APC	Smart-UPS 3000	Respaldo de Energía (UPS)	3000 VA	N/A	SN-PWR-001	Mantenimiento	12/05/2023	Site Central Planta 2
9	TP-Link	Archer AX55	Router Wifi (Temporal)	3 Gbps	1.5 GHz	SN-WIFI-001	No Autorizado	05/01/2026	Área de Producción
10	Dell	OptiPlex 7090	Estación de Trabajo	16 GB RAM	3.4 GHz	SN-WIN-9501	Sin Antivirus	14/06/2024	Operador Planta 3

Organización	Empresa Automotriz
Área	Tecnologías de la Información / Seguridad Lógica
Responsable	Luis Alberto Vargas Gonzalez

Actualizado al día	24/03/2026
--------------------	------------

No	Nombre	Tipo de Software	Tipo de Licencia	Descripción	Caducidad	Num Serie	Estado	Fecha de asignación	Asignado a
1	IBM DB2	Base de Datos	Corporativa	Motor de BD para Manufactura	31/12/2026	DB2-ENT-99	Sin Parches	01/01/2021	Site Central Planta 1
2	Oracle Database	Base de Datos	Corporativa	Gestión de inventarios	15/05/2026	ORA-DB-88	Sin Parches	10/02/2021	Site Central Planta 2
3	MS SQL Server	Base de Datos	Corporativa	Datos Administrativos	20/08/2026	SQL-SVR-77	Vulnerable	15/03/2021	Site Central Planta 3
4	Windows Server	S.O. Servidor	Enterprise	Sistema Operativo de Red	Permanente	WIN-SRV-030	Desactualizado	12/03/2022	30 Servidores Locales
5	IBM AIX	S.O. Servidor	Propietaria	Sistema para Mainframes	Permanente	AIX-72-UNIX	Activo	20/01/2022	15 Servidores Unix
6	Avast Free	Antivirus	Freeware	Protección de Endpoint	N/A	N/A	Inseguro	10/06/2024	Laptops Administrativas
7	Office 365	Ofimática	A granel	Herramientas de Productividad	01/10/2026	O365-BLK-50	Sin Control	15/01/2025	15,000 Usuarios
8	Call Of Duty	Videojuego	Gratuita	Software no autorizado	N/A	N/A	Prohibido	05/01/2026	Equipos de planta
9	Adobe Suite	Diseño	Suscripción	Herramientas multimedia	12/12/2026	ADOBE-MUN-01	Activo	02/02/2025	Centro Diseño Múnich
10	AnyDesk	Acceso remoto a equipos	Gratuita	Acceso remoto no oficial	N/A	N/A	En Riesgo	14/02/2026	Equipos de Desarrollo

AVANCE DE PROYECTO INTEGRADOR

Controles de seguridad

Nombre del
alumno:

Luis Alberto Vargas Gonzalez

I. Administración de servicios de seguridad

Servicio de Gestión de Identidades y Acceso (IAM / Active Directory):

- Es vital para administrar centralizadamente a los **35,000 empleados** y eliminar el riesgo del "full access" generalizado, permitiendo aplicar el principio de menor privilegio.

Servicio de Almacenamiento y Respaldo de Datos (Backup as a Service):

- Dado que actualmente solo se respalda una cuarta parte de la información, se requiere un servicio que garantice la integridad y disponibilidad de los diseños premium y datos de manufactura.

Servicio de Conectividad Segura y Perimetral (VPN y Firewalls Next-Gen):

- Necesario para interconectar de forma segura las plantas ensambladoras con el centro de diseño en Múnich y permitir el acceso remoto seguro a los ingenieros de software.

Servicio de Protección de Endpoints (EDR - Endpoint Detection and Response):

- Para sustituir las versiones gratuitas de antivirus y proteger las **15,000 computadoras** (Windows y macOS) contra amenazas avanzadas ransomware.

Servicio de Gestión y Seguridad de Bases de Datos (Database Security):

- Crucial para monitorear y proteger los motores **DB2, Oracle y SQL Server** que llevan 3 años sin parches, asegurando la continuidad del proceso de manufactura.

II. Administración de riesgos

1. Infección por Malware/Ransomware: Debido al uso de antivirus gratuitos (Avast Free) en los 10,000 equipos personales, lo que deja a la empresa sin protección proactiva ante ataques modernos.

2. Acceso No Autorizado y Fuga de Información: Provocado por la política de "Full Access" generalizado, permitiendo que cualquier empleado acceda o modifique diseños premium de software y hardware sin restricción.

3. Explotación de Vulnerabilidades Críticas en Bases de Datos: Los motores Oracle, DB2 y SQL Server llevan 3 años sin parches de seguridad, lo que facilita ataques de inyección o robo de datos de manufactura.

4. Interrupción de Operaciones por Falla de Red: El equipo Cisco con más de 5 años de antigüedad y sin actualizaciones de firmware aumenta la probabilidad de caídas del sistema y huecos de seguridad en el perímetro.

5. Pérdida Irrecuperable de Datos Críticos: La falta de capacidad de almacenamiento para respaldos (solo se cubre el 25%) implica que ante un desastre, la mayoría de la información de diseño se perdería para siempre.

6. Intrusión Física a Áreas Restringidas: La inoperatividad de las cámaras de seguridad y la falta de control en los gafetes de proximidad permiten que personas no autorizadas ingresen a laboratorios de desarrollo.

7. Daños Físicos al Personal en Múnich: La zona sísmica de alta peligrosidad combinada con la inexistencia de un plan de evacuación pone en riesgo la vida de los ingenieros en el centro de diseño.

8. Introducción de Amenazas vía Shadow IT: La libertad de los empleados para instalar software (como *Warzone* o *AnyDesk*) introduce puertas traseras y malware en la red corporativa bajo el radar de TI.

9. Robo de Propiedad Intelectual: La falta de convenios de confidencialidad y control de invitados facilita que los diseños de autos deportivos y premium sean filtrados a la competencia.

10. Indisponibilidad del Servicio por Mantenimiento Prolongado: Ventanas de mantenimiento de hasta 2 días sin esquemas de alta disponibilidad afectan la productividad de las plantas ensambladoras a nivel mundial.

III. Soluciones de seguridad

Implementación de Control de Acceso Basado en Roles (RBAC) con MFA:

- Se debe desplegar un sistema de Gestión de Identidades (IAM) que elimine el "Full Access" generalizado, asignando permisos mínimos necesarios a los **35,000 empleados** y requiriendo Autenticación de Múltiple Factor (MFA) para acceder a los diseños premium de software y hardware.
- **Atiende:** Servicios de seguridad e Intercambio de información.

Infraestructura de Respaldo Híbrida con Redundancia Geográfica:

- Expandir la capacidad de almacenamiento para cubrir el 100% de la información crítica mediante una solución híbrida (Local + Nube), asegurando que los datos del centro de diseño en Múnich tengan réplicas en una zona de bajo riesgo sísmico para garantizar la disponibilidad.
- **Atiende:** Respaldos.

Renovación de Perímetro y Segmentación de Red (NGFW):

- Sustituir el equipo Cisco obsoleto por Firewalls de Nueva Generación (NGFW) que permitan segmentar la red de las plantas industriales de la red de oficinas, utilizando túneles VPN cifrados para el intercambio de datos entre sucursales y el centro de diseño.
- **Atiende:** Seguridad de red e intercambio de información.

Despliegue de Protección Avanzada de Endpoints (EDR):

- Instalar una solución de detección y respuesta en los **15,000 equipos** (Windows y macOS) para sustituir el antivirus gratuito. Esta herramienta permitirá bloquear la ejecución de software no autorizado (como *Warzone*) y detectar comportamientos sospechosos de ransomware en tiempo real.
- **Atiende:** Servicios de seguridad y Riesgos enlistados.

Blindaje y Monitoreo de Bases de Datos (Database Vault):

- Implementar soluciones de cifrado y "parchado virtual" para los motores **Oracle, DB2 y SQL Server**. Esto protege la integridad de los datos de manufactura mientras se ejecutan los mantenimientos pendientes, registrando cada intento de acceso o modificación en una bitácora de auditoría.
- **Atiende:** Servicios de seguridad e intercambio de información.

IV. Respaldos de información

Para garantizar la disponibilidad e integridad de los activos de información de la empresa automotriz, la administración de respaldos se regirá bajo los siguientes pilares técnicos y estratégicos:

- **Implementación de la Estrategia 3-2-1:** Se establecerá un esquema donde existan **3 copias** de los datos (la original y dos respaldos), almacenadas en **2 medios** distintos (ej. Disco local de alta velocidad para recuperación rápida y Almacenamiento en la Nube), con **1 copia fuera de sitio** (*off-site*). Esta copia externa es crítica para el centro de diseño en Múnich, debiendo situarse en una región geográfica con bajo riesgo sísmico.
- **Clasificación Basada en el BIA (Business Impact Analysis):** No toda la información se respalda igual. Se priorizarán los diseños de hardware premium, bases de datos de manufactura (DB2, Oracle, SQL Server) y código fuente multimedia, asignándoles un **RPO (Objetivo de Punto de Recuperación)** cercano a cero para minimizar la pérdida de datos en caso de falla.
- **Cifrado e Integridad de los Datos:** Todos los respaldos deberán estar cifrados tanto en tránsito como en reposo utilizando algoritmos de grado industrial (AES-256). Se utilizarán funciones *hash* para verificar la integridad de las copias y asegurar que la información no haya sido alterada durante el proceso de almacenamiento.

- **Automatización y Ventanas de Ejecución:** Para evitar afectar la productividad de las plantas ensambladoras, los respaldos completos se programarán en horas de baja carga operativa, mientras que los respaldos incrementales o diferenciales se ejecutarán continuamente para capturar cambios en tiempo real sin degradar el rendimiento de la red Cisco.
- **Pruebas de Restauración y Cumplimiento de RTO:** Se realizará un calendario mensual de pruebas de restauración aleatorias. El objetivo es validar que el **RTO (Objetivo de Tiempo de Recuperación)** definido por la gerencia sea alcanzable, garantizando que los sistemas críticos puedan estar operativos en el menor tiempo posible tras un incidente.

V. Estrategias de seguridad

Para modernizar la infraestructura y proteger los activos críticos, se implementarán las siguientes estrategias:

- **Segmentación de Red mediante VLANs y Micro-segmentación:**
 - **Explicación:** Se dividirá la red lógica en diferentes segmentos aislados (VLANs) para separar el tráfico de las plantas ensambladoras, el área administrativa, el centro de diseño y la zona de servidores/mainframes.
 - **Justificación:** Evita el movimiento lateral de amenazas; si un equipo en la planta se infecta con *malware* (como por el uso de *Warzone*), la infección no podrá llegar a los mainframes o a las bases de datos críticas de manufactura.
- **Despliegue de Firewalls de Nueva Generación (NGFW):**
 - **Explicación:** Sustitución del equipo Cisco obsoleto por dispositivos que integren inspección profunda de paquetes (DPI), filtrado de contenido web y control de aplicaciones.
 - **Justificación:** Permite bloquear aplicaciones no autorizadas (Shadow IT) y detectar intentos de explotación en los motores Oracle y DB2 que actualmente carecen de parches de seguridad.

- **Implementación de Túneles VPN Site-to-Site con Cifrado Robusto:**
 - **Explicación:** Establecimiento de conexiones cifradas (IPsec) permanentes para la comunicación entre las tres plantas y el centro de diseño en Múnich.
 - **Justificación:** Garantiza que el intercambio de propiedad intelectual y diseños premium a través de internet sea confidencial e íntegro, mitigando el riesgo de interceptación de datos.
- **Sistemas de Detección y Prevención de Intrusiones (IDS/IPS):**
 - **Explicación:** Colocación de sensores en puntos estratégicos de la red para monitorear el tráfico en busca de patrones de ataque conocidos.
 - **Justificación:** Actúa como una capa de seguridad crítica para proteger los sistemas que tienen un ciclo de vida de mantenimiento lento, como los mainframes y servidores Unix.
- **Control de Admisión de Red (NAC):**
 - **Explicación:** Sistema que valida la identidad y el estado de seguridad de cualquier dispositivo antes de permitirle unirse a la red corporativa.
 - **Justificación:** Asegura que solo los equipos registrados en el inventario de hardware tengan acceso, bloqueando dispositivos externos o routers no autorizados instalados por los empleados.

VI. Políticas y controles de seguridad

Para asegurar que la transferencia de datos técnicos y administrativos sea protegida contra intercepciones o modificaciones no autorizadas, se establecen las siguientes medidas:

Políticas de Seguridad (Marco Administrativo)

- **Política de Clasificación de la Información:** Se establece la obligatoriedad de etiquetar todo activo de información (p. ej., "Público", "Uso Interno", "Confidencial" o "Restringido") antes de su envío. Esto define el nivel de protección que el dato requiere durante su intercambio.
- **Acuerdos de Confidencialidad (NDA):** Todo empleado o tercero con acceso a diseños de hardware y software debe firmar convenios legales que prohíban la divulgación de información propietaria.

Política de Uso Aceptable (AUP): Documento que dicta las reglas sobre qué plataformas y métodos son permitidos para el intercambio de archivos, prohibiendo explícitamente el uso de servicios de almacenamiento personal en la nube o herramientas de acceso remoto no oficiales como *AnyDesk*.

Controles de Seguridad (Implementación Técnica)

- **Cifrado de Datos en Tránsito (TLS/SSL y IPsec):** Toda comunicación entre las plantas y el centro de diseño debe realizarse a través de túneles VPN cifrados que utilicen protocolos robustos para garantizar la confidencialidad de los datos mientras viajan por redes públicas.
- **Firmas Digitales y No Repudio:** Se implementará el uso de certificados digitales para firmar documentos técnicos y aprobaciones de diseño. Esto garantiza la integridad del mensaje y asegura que el emisor no pueda negar haber enviado la información.
- **Sistemas de Prevención de Fuga de Datos (DLP):** Control técnico que monitorea y bloquea el intercambio de archivos que contengan patrones de propiedad intelectual protegida (como planos de motores o código fuente) a través de correo electrónico o dispositivos USB no autorizados.
- **Protocolos de Transferencia Segura (SFTP/HTTPS):** Se eliminará el uso de protocolos inseguros (como FTP simple) para el intercambio de archivos de gran tamaño, exigiendo canales que cifren tanto las credenciales de acceso como el contenido transferido.

VII. Monitoreo

Para garantizar la visibilidad total de la infraestructura y la detección oportuna de incidentes, se implementará un ecosistema de monitoreo centralizado basado en las siguientes capas técnicas:

- **Inteligencia de Seguridad y Correlación (SIEM - Splunk):**
 - Se utilizará **Splunk** para centralizar y correlacionar los logs de los 30 servidores Windows, los 15 servidores Unix/Mainframes y los 15,000 endpoints.
 - El enfoque principal será la detección de anomalías en el comportamiento de los usuarios (UBA) para identificar accesos no autorizados a diseños premium derivados del "Full Access" actual.
- **Orquestación y Respuesta Automatizada (SOAR):**
 - Se integrará una plataforma **SOAR** para automatizar el triaje de incidentes. Por ejemplo, ante la detección de software no autorizado como *Call of Duty* o *AnyDesk*, el SOAR ejecutará automáticamente un playbook para aislar el equipo de la red y generar el reporte de incidente en tiempo real.

- **Monitoreo de Salud y Rendimiento (Prometheus y Grafana):**
 - Se desplegará **Prometheus** para la recolección de métricas de hardware y servicios, visualizadas en tableros de **Grafana**.
 - Esto es crítico para monitorear el equipo Cisco con más de 5 años de antigüedad, permitiendo predecir fallas por desgaste de componentes antes de que afecten la producción en las plantas.
- **Monitoreo de Actividad de Bases de Datos (DAM):**
 - Dado que los motores Oracle, DB2 y SQL Server carecen de parches, se implementará un monitoreo específico sobre las consultas y modificaciones en estas tablas. Cualquier intento de inyección de código o extracción masiva de datos de manufactura disparará una alerta crítica inmediata.
- **Control de Acceso Físico y Bitácoras de Identidad:**
 - Se integrará el sistema de **gafetes con ID** a la plataforma de monitoreo para registrar cada entrada y salida de las plantas y laboratorios.
 - El sistema generará alertas si un empleado intenta acceder a áreas restringidas fuera de su horario laboral o si se detecta un "ingreso doble" con la misma credencial, resolviendo la falta de control físico reportada.

- **Monitoreo Ambiental en el Centro de Diseño (Múnich):**
- Se instalarán sensores de actividad sísmica y condiciones ambientales conectados al SIEM. Ante cualquier vibración que supere el umbral de seguridad, el sistema activará automáticamente los protocolos de emergencia y evacuación para proteger al personal.

AVANCE DE PROYECTO INTEGRADOR

Planes de Respuesta a Incidentes

Alumno: Luis Alberto Vargas Gonzalez.

Maestría en Ciberseguridad.

I. Introducción al plan continuidad de negocio

El presente **Plan de Continuidad del Negocio (BCP)** tiene como objetivo principal garantizar que la empresa automotriz mantenga sus operaciones críticas ante cualquier interrupción mayor, protegiendo la integridad de sus **35,000 empleados** y su valiosa propiedad intelectual. Este plan maestro se integra por dos subplanes fundamentales que trabajan en conjunto:

1º Plan de Recuperación de Desastres (DRP): Es el brazo técnico del BCP. Se enfoca exclusivamente en la restauración de la infraestructura de TI, incluyendo la recuperación de los **mainframes IBM**, los servidores de bases de datos (**Oracle, DB2, SQL Server**) y la conectividad de la red **Cisco**. Su meta es cumplir con los tiempos de recuperación (RTO) definidos para los sistemas que sostienen la manufactura.

2º Plan de Recuperación del Negocio (BRP): Se centra en los procesos humanos y operativos. Define cómo deben actuar los departamentos (como el centro de diseño en Múnich o las plantas ensambladoras) para seguir funcionando mientras la tecnología es restaurada, incluyendo protocolos de reubicación de personal y comunicación de crisis.



II. Análisis y valoración de riesgos

Riesgo Identificado	Valoración (Impacto/Prob.)	Consecuencias Técnicas y de Negocio
1. Actividad Sísmica en Múnich.	Crítico / Alta	Pérdida de vidas humanas, destrucción física del centro de diseño y pérdida total de la propiedad intelectual premium no respaldada.
2. Explotación de BD sin parches (Oracle/DB2).	Alto / Alta	Robo de secretos industriales de manufactura y alteración maliciosa de registros de producción.
3. Falla de Infraestructura Cisco Obsoleta.	Alto / Media	Interrupción total de la conectividad entre plantas, detención de la cadena de suministro y parálisis operativa.
4. Exfiltración por "Full Access" Generalizado.	Medio / Alta	Fuga de información confidencial facilitada por empleados con privilegios excesivos, dañando la ventaja competitiva.
5. Ransomware vía Software No Autorizado.	Crítico / Media	Cifrado masivo de estaciones de trabajo y servidores, detención de actividades y posible extorsión económica.



Planes, Programas y Procedimientos

Riesgo Identificado	Valoración (Impacto/Prob.)	Consecuencias Técnicas y de Negocio
6. Pérdida de Datos por Respaldos Insuficientes.	Crítico / Alta	Incapacidad de restaurar la operación tras un incidente, resultando en la pérdida del 75% de la información histórica.
7. Intrusión Física por Fallo de Monitoreo.	Medio / Media	Robo de prototipos físicos en laboratorios y manipulación directa de hardware crítico por personas ajenas.
8. Downtime por Mantenimiento Prolongado.	Bajo / Alta	Pérdida de productividad planificada y retrasos significativos en los ciclos de entrega de vehículos premium.
9. Fuga de Datos vía Shadow IT (AnyDesk).	Alto / Alta	Apertura de "puertas traseras" que eluden el perímetro de seguridad, permitiendo el robo de datos sin dejar rastro en el SIEM.
10. Denegación de Servicio (DoS) en Mainframes	Alto / Media	Inoperatividad de los sistemas centrales que controlan los procesos robotizados de las plantas ensambladoras.



III. Medidas preventivas

1. Establecimiento de un Sitio de Recuperación Alterno (Hot Site): Implementar una sede espejo fuera de la zona sísmica de Múnich para asegurar que los ingenieros de diseño puedan retomar actividades de inmediato si el edificio principal sufre daños estructurales.

2. Ciclo de Vida de Activos y "Hardware Refresh": Programar la sustitución obligatoria del equipo Cisco cada 3 o 4 años, asegurando que la infraestructura de red siempre cuente con soporte del fabricante y actualizaciones de firmware vigentes.

3. Implementación de un Programa de Gestión de Vulnerabilidades: Ejecutar un calendario de parchado mensual para los motores de base de datos Oracle, DB2 y SQL Server, utilizando técnicas de "virtual patching" para proteger sistemas críticos mientras se programan las ventanas de mantenimiento.

4. Adopción del Principio de Menor Privilegio (RBAC): Configurar una matriz de control de acceso basada en roles donde el "Full Access" sea eliminado y cada uno de los **35,000 empleados** solo tenga permisos para los datos estrictamente necesarios para su función.

5. Despliegue de EDR (Endpoint Detection and Response): Sustituir los antivirus gratuitos por una solución empresarial de detección y respuesta que bloquee automáticamente la instalación de software no autorizado como *Call of Duty* o *AnyDesk*.



6. Automatización de la Estrategia de Respaldo 3-2-1: Incrementar la capacidad de almacenamiento para garantizar que el 100% de la información crítica sea respaldada, manteniendo al menos una copia cifrada en una región de nube distinta a la ubicación física de las plantas.

7. Fortalecimiento de la Seguridad Perimetral Física: Reparar el sistema de cámaras de circuito cerrado (CCTV) e implementar controles biométricos de acceso en laboratorios para evitar intrusiones físicas no autorizadas.

8. Configuración de Alta Disponibilidad (HA): Implementar clústeres redundantes para los servicios críticos y mainframes, permitiendo que un nodo asuma la carga si otro falla, reduciendo las ventanas de mantenimiento de 2 días a solo minutos.

9. Filtrado de Contenido Web y Whitelisting: Implementar políticas de control en el firewall para permitir únicamente el tráfico hacia sitios y aplicaciones de negocio, mitigando el riesgo de descargas maliciosas desde internet.

10. Sistemas de Prevención de Intrusiones (IPS) para Mainframes: Colocar sensores de red especializados frente a los servidores Unix e IBM que detecten y bloqueen intentos de Denegación de Servicio (DoS) antes de que afecten la línea de producción



IV. Principales procesos identificados

Descripción	Costo	Riesgos	Impacto en caso de suspensión	Observaciones
Mainframe IBM z15 (Producción)	Alto	Medio	Alto	Controla el ensamble robotizado; su caída detiene la producción global.
Core de Red Cisco (Plantas y Múnich)	Alto	Alto	Alto	Equipo obsoleto de +5 años; si falla, se pierde la conexión entre sedes.
Servidores de BD (Oracle/DB2/SQL)	Medio	Alto	Alto	Almacenan diseños y datos de manufactura; vulnerables por falta de parches.
Laptops/Workstations de Diseño en Múnich.	Alto	Alto	Alto	Interrupción del ciclo de diseño de piezas premium; riesgo de pérdida total de IP (Propiedad intelectual) por falta de respaldos externos.
Unidades de almacenamiento para respaldos corporativos.	Alto	Alto	Alto	Capacidad actual insuficiente (25%); su falla implica pérdida total de IP y posibles demandas por incumplimiento de contratos.
Sistemas de Control Industrial (PLCs/Línea de Ensamble)	Alto	Medio	Alto	La suspensión detiene físicamente la manufactura de vehículos; riesgo de daños a maquinaria.
Directorio Activo / Servicio de Identidad (IAM)	Medio	Alto	Alto	Si se suspende, nadie puede loguearse; facilita el "Full Access" actual si no se controla.
Sistemas de Seguridad Física (CCTV y Gafetes)	Medio	Alto	Medio	Inoperantes actualmente; su suspensión permite el robo de prototipos físicos.



V. Respaldo y recuperación de información

Tipo	Clasificación	Consecuencias	Modo de recuperación
Ataque Ransomware Masivo	Crítico	Cifrado de bases de datos de manufactura y pérdida de acceso a diseños en Múnich.	1. Aislamiento de red y segmentación vía ACLs. 2. Activación de TPM y reseteo de fábrica con cambio de SO. 3. Restauración de BD desde respaldos limpios validados.
Incendio	Grave	Pérdida total de servidores físicos y estaciones de trabajo en planta.	Adquisición de hardware nuevo y restauración desde la copia de seguridad en la nube (fuera de sitio).
Temblor (Múnich)	Grave	Daño estructural y pérdida de diseños premium no respaldados localmente.	Activación del Hot Site en zona segura. Recuperación de diseños mediante el "Cold Backup" de workstations no dañadas y sincronización con nube.
Robo de Equipo	Bajo	Exfiltración de IP y pérdida de activos físicos.	Bloqueo remoto de cuentas (IAM), revocación de certificados y restauración de la imagen del sistema en equipo nuevo.
Epidemia/Pandemia	Alto	Inoperatividad presencial de los 35,000 empleados.	Despliegue masivo de túneles VPN cifrados y virtualización de aplicaciones para permitir el diseño y administración remota segura.
Toma Hostil / Terrorismo	Crítico	Riesgo de pérdida de vidas, robo de IP física y parálisis total.	Activación inmediata del Comité de Crisis. Notificación a autoridades. Bloqueo remoto de sistemas críticos. Reubicación de funciones al Hot Site.
Interrupción de Suministro Eléctrico	Alto	Paro total de líneas de producción, riesgo de corrupción en bases de datos y pérdida de visibilidad en monitoreo de seguridad.	Activación de UPS para cierre ordenado de sistemas críticos. Uso de plantas de emergencia (generadores). Transferencia de cargas administrativas al Hot Site o centro redundante.



AVANCE DE PROYECTO INTEGRADOR

Plan de Normas de Seguridad

I. ISO 27001

Para implementar el estándar **ISO/IEC 27001:2022** en la empresa automotriz y establecer un Sistema de Gestión de Seguridad de la Información (SGSI) sólido, seguiría el ciclo de mejora continua **PDCA** (Plan-Do-Check-Act) enfocado en los activos críticos del caso:

1º Fase de Planificación (Plan): Definiría el alcance del SGSI, incluyendo el Centro de Diseño en Múnich y las plantas de manufactura. Es fundamental realizar un análisis de riesgos para los activos identificados (Mainframes, BD Oracle/DB2 y Red Cisco) y seleccionar los controles aplicables del **Anexo A** de la norma, como el control A.5.15 (Clasificación de la información) para proteger los diseños premium.

2º Fase de Implementación (Do): Desplegaría los controles técnicos y administrativos necesarios. Esto incluye eliminar el "Full Access" generalizado mediante el control A.5.18 (Derechos de acceso) y sustituir los antivirus gratuitos por una solución de grado empresarial (EDR).

3º Fase de Verificación (Check): Establecería indicadores de cumplimiento y realizaría revisiones periódicas. Por ejemplo, monitorear mediante **Splunk** si se cumplen las políticas de acceso a las bases de datos y si se están realizando los respaldos del 100% de la información.

4º Fase de Mejora (Act): Con base en las auditorías internas, realizaría los ajustes necesarios. Si se detecta que el personal sigue descargando software no autorizado (Shadow IT), se reforzaría el programa de concienciación y se ajustarían los bloqueos en el firewall.



II. Marco de seguridad COBIT

Para alinear la normativa de la empresa con **COBIT**, debemos pasar de solo "gestionar la seguridad" a "**gobernar la información y la tecnología**". COBIT se enfoca en que la TI entregue valor y los riesgos estén alineados con los objetivos del negocio.

Estos son los cambios clave que implementaría en la normativa:

- **Separación de Gobierno y Gestión:** Establecería una norma que distinga claramente las responsabilidades del Consejo Directivo (que evalúa y orienta) de las del equipo de TI (que ejecuta y monitorea).
- **Alineación con Objetivos Estratégicos:** La normativa debe exigir que cada control de seguridad (como el respaldo del 100% de la información) esté vinculado a un objetivo de negocio, como la "Continuidad de la Manufactura".
- **Implementación de Métricas y KPIs:** Cambiaría la norma de "hacer respaldos" por una que exija reportar el **% de éxito de restauración** y el **tiempo de inactividad**, alineándose con el dominio de **MEA (Monitorear, Evaluar y Valorar)** de COBIT.
- **Gestión de Riesgos Transparente:** La normativa obligaría a crear un Registro de Riesgos corporativo donde la alta dirección acepte formalmente los riesgos residuales, especialmente los relacionados con los mainframes obsoletos y la zona sísmica de Múnich.
- **Control de Calidad en el Desarrollo:** Para el software automotriz premium, la norma debe integrar controles de calidad y seguridad desde el diseño (DevSecOps), siguiendo el dominio **BAI (Construir, Adquirir e Implementar)** de COBIT.



III. Marco NIST

Para que la empresa avance en el marco NIST, la normativa debe modificarse para reflejar el paso de un estado reactivo a uno proactivo:

- **Nivel 1: Parcial (Estado Actual):**

- **Modificación:** La normativa actual es informal y reactiva. Se debe formalizar la existencia de un inventario de activos y una política básica de accesos para dejar de gestionar la seguridad de forma "ad-hoc".

- **Nivel 2: Informado por el Riesgo:**

- **Modificación:** La normativa debe exigir que la alta dirección apruebe formalmente las prácticas de gestión de riesgos. Se debe incluir la obligatoriedad de realizar un análisis de impacto al negocio (BIA) antes de priorizar presupuestos en TI.

- **Nivel 3: Repetible:**

- **Modificación:** Las políticas de seguridad deben estar documentadas, aprobadas y comunicadas a los **35,000 empleados**. La norma debe exigir procesos estandarizados para el parchado de bases de datos (Oracle/DB2) y la renovación de hardware Cisco, asegurando que no dependan del conocimiento de una sola persona.

- **Nivel 4: Adaptativo:**

- **Modificación:** La normativa debe evolucionar para incluir el **monitoreo continuo** y la detección predictiva. Se debe integrar el uso de **Splunk y SOAR** como norma para aprender de eventos pasados y ajustar los controles de forma dinámica antes de que ocurra un nuevo incidente.



IV. Criterios comunes

Para la empresa automotriz, estos son los criterios que yo incluiría:

- 1º **Evaluación de EAL (Evaluation Assurance Level):** Exigir que cualquier software crítico de control de frenado o motor tenga un nivel de seguridad certificado (ej. EAL4+) para garantizar que ha sido probado contra ataques.
- 2º **Seguridad en el Ciclo de Vida (Flaw Remediation):** Los sistemas deben tener un mecanismo certificado para recibir parches de seguridad de forma segura, evitando que los motores Oracle/DB2 vuelvan a quedar 3 años desactualizados.
- 3º **Protección de Datos en Reposo y Tránsito:** Todo producto de hardware premium desarrollado en Múnich debe cumplir con criterios de cifrado validados (como FIPS 140-2) para evitar que la IP sea robada si un prototipo es interceptado.
- 4º **Autenticación Robusta:** Los sistemas de acceso a la planta y laboratorios deben cumplir con criterios de biometría y MFA que aseguren que el "Full Access" actual sea imposible de explotar por terceros.



V. Cumplimiento de normas

Para asegurar que las normativas basadas en ISO 27001, COBIT y NIST sean efectivas, implementaremos el siguiente plan de cumplimiento:

1º Programa de Concientización y Capacitación (Cultura de Seguridad):

- **Acción:** Realizar talleres trimestrales obligatorios para los 35,000 empleados sobre riesgos de "Shadow IT" (software no autorizado) y phishing.
- **Vínculo:** Cumple con la función de **Proteger** de NIST al reducir el error humano.

2º Mecanismos de Control Técnico (Enforcement):

- **Acción:** Configurar el Firewall y el EDR para bloquear automáticamente cualquier instalación no permitida (como *Warzone* o *AnyDesk*), eliminando la posibilidad de incumplir la norma por "descuido".
- **Vínculo:** Alineado con el dominio **BAI** de COBIT (Construir, Adquirir e Implementar).

3º Monitoreo Continuo y Auditoría de Cumplimiento:

- **Acción:** Utilizar **Splunk** para generar reportes semanales de cumplimiento. Cualquier desviación (ej. un servidor de base de datos Oracle sin el parche del mes) generará una alerta inmediata al responsable.
- **Vínculo:** Cumple con el dominio **MEA** de COBIT (Monitorear, Evaluar y Valorar).

4º Política de Sanciones y Reconocimientos:

- **Acción:** Actualizar el reglamento interior de trabajo para incluir sanciones administrativas a quienes violen deliberadamente las normas de seguridad (ej. compartir diseños premium sin cifrado).
- **Vínculo:** Refuerza la gobernanza exigida por ISO 27001.



VI. Auditorias

El plan de auditoría se ejecutará bajo un enfoque basado en riesgos, evaluando la eficacia de los controles técnicos y administrativos sobre los activos identificados en el caso.

1. Alcance de la Auditoría

Se auditarán los tres pilares que sostienen la operación de las plantas y el centro de diseño:

- **Gestión de Datos:** Motores Oracle, DB2 y SQL Server.
- **Continuidad:** Sistemas y procesos de respaldo y recuperación.
- **Infraestructura de Transporte:** Red Core Cisco y conectividad entre sedes.

2. Objetivos y Pruebas Técnicas

Activo IT	Objetivo de la Auditoría	Prueba de Auditoría (Evidencia)
Bases de Datos (Oracle/DB2/SQL)	Verificar la integridad y el control de acceso a los diseños e IP.	Revisión de logs de acceso en Splunk , verificación de versiones/parches y pruebas de inyección controladas.
Sistemas de Respaldo	Validar que el 100% de la información crítica sea recuperable.	Ejecución de una prueba de restauración completa (Restore Test) y validación de la capacidad de almacenamiento actual.



Activo IT	Objetivo de la Auditoría	Prueba de Auditoría (Evidencia)
Red Core Cisco	Asegurar la disponibilidad de la comunicación y la segmentación de tráfico.	Análisis de vulnerabilidades en equipos de más de 5 años y revisión de las reglas de ACLs para prevenir el "Full Access".

3. Cronograma de Ejecución

- **Semana 1-2:** Auditoría de Bases de Datos (Prioridad por volumen de I/O y valor de IP).
- **Semana 3:** Auditoría de Resiliencia (Respaldos y DRP).
- **Semana 4:** Auditoría de Infraestructura de Red y Perímetro.



AVANCE DE PROYECTO INTEGRADOR

Programa de Concientización

I. Planeación.

El objetivo de este programa es transformar la cultura organizacional de la empresa automotriz, pasando de la "apatía" actual a una responsabilidad compartida en ciberseguridad. La planeación se divide en las siguientes etapas técnicas y estratégicas:

- 1º **Identificación de Audiencias:** Segmentaremos a los **35,000 colaboradores** en perfiles específicos: Personal de Diseño (Múnich), Operarios de Planta, Personal Administrativo y Alta Dirección. Cada grupo recibirá contenido adaptado a sus riesgos específicos (ej. espionaje industrial para Múnich vs. seguridad física para plantas).
- 2º **Evaluación de la Línea Base:** Antes de lanzar el programa, realizaremos una simulación de phishing y una auditoría de "Shadow IT" para medir cuántos usuarios siguen instalando software no autorizado.
- 3º **Definición de Temas Críticos:** El contenido se centrará en los problemas detectados en el caso:
 - Uso aceptable de activos (prohibición de software recreativo como *Warzone*).
 - Protección de Propiedad Intelectual y Clasificación de Información (Diseños Premium).
 - Reporte de incidentes y uso de canales oficiales de soporte.
- 4º **Selección de Canales:** Utilizaremos una plataforma de **LMS (Learning Management System)** para cursos interactivos, boletines informativos vía correo electrónico y protectores de pantalla con consejos de seguridad en todas las estaciones de trabajo.
- 5º **Métricas de Éxito (KPIs):** Mediremos la efectividad mediante la reducción en el número de infecciones por malware y el aumento en el reporte proactivo de correos sospechosos al SOC.



II. Aspectos legales.

El programa de concientización se fundamentará en los marcos legales internacionales que rigen a la industria automotriz y las ubicaciones confirmadas en el caso:

1º Reglamento General de Protección de Datos (GDPR):

- Dado que el centro de diseño se encuentra en **Múnich**, es obligatorio cumplir con el **GDPR**. El programa concientizará a los empleados sobre el tratamiento de datos de los **35,000 colaboradores** y el manejo de información técnica que pueda contener datos personales, evitando sanciones millonarias por parte de las autoridades europeas.

2º Protección de la Propiedad Intelectual e Industrial (OMPI/WIPO):

- Se instruirá sobre los tratados internacionales de protección de patentes y diseños industriales. Los empleados deben comprender que el robo o fuga de los "diseños premium" constituye un delito de espionaje industrial bajo marcos de cooperación internacional, independientemente de dónde se encuentre la planta.

3º Leyes Locales de la Sede de Manufactura:

- El programa incluirá un módulo genérico sobre el cumplimiento de la legislación de protección de datos y ciberseguridad aplicable en el país donde se ubican las plantas de ensamble, asegurando que los operarios conozcan sus deberes legales locales.

4º Derecho Laboral y Políticas de Uso Aceptable:

- Se explicará la base legal que permite a la empresa sancionar el uso de activos para fines no laborales (como el uso de *Warzone* o *AnyDesk*). Se enfatizará que la violación de las normas de seguridad puede ser causa de rescisión de contrato según las leyes laborales vigentes en cada sede.

5º Acuerdos de Confidencialidad y No Divulgación (NDA):

- Se reforzará la validez legal de los contratos de confidencialidad firmados por el personal de diseño y manufactura, detallando las consecuencias civiles y penales de la exfiltración de información confidencial.



III. Responsabilidades

Nivel Jerárquico	Responsabilidades Principales
Directivos/Altos Mandos	• Autorizar y asignar el presupuesto necesario para la actualización de infraestructura obsoleta y sistemas de respaldo. • Liderar con el ejemplo, participando activamente en las sesiones de concientización para eliminar la "apatía" institucional. • Aprobar la Estrategia Global de Ciberseguridad, asegurando que la protección de la propiedad intelectual sea vista como un activo de valor agregado para la empresa.
Gerentes/ Mandos Medios	• Supervisar el cumplimiento de la Política de Uso Aceptable (AUP), iniciando procesos administrativos y planes de re-capacitación ante la



	detección de software no autorizado. • Gestionar los accesos bajo el Principio de Privilegio Mínimo, configurando correctamente los grupos en Active Directory. • Actuar como reguladores y mediadores entre la dirección y el personal operativo durante auditorías e incidentes. • Mantener programas de vigilancia permanente para erradicar la apatía y reportar periódicamente el estado táctico de seguridad de su área.
Usuarios Finales	• Actuar como la primera línea de defensa y contacto, reportando inmediatamente cualquier movimiento extraño, físico o digital, en sus áreas de trabajo. • Mantener estándares de honestidad, integridad y profesionalismo al colaborar en la resolución de incidencias de seguridad. • Manejar con absoluta discreción los diseños y la IP, restringiendo su uso al área y horario laboral, prohibiendo



	estrictamente su divulgación o compartición. • Incrementar obligatoriamente sus estándares de higiene digital conforme avancen en los ciclos de capacitación técnica previstos.
--	--



IV. Plan de impartición

Para asegurar que la ciberseguridad se convierta en un hábito para los 35,000 colaboradores, el plan de impartición se ejecutará de manera cíclica y dinámica bajo los siguientes ejes:

1. Ciclos de Actualización Cuatrimestral:

- Se establecerán tres periodos de capacitación obligatoria al año (cada 4 meses). Esta frecuencia permite reaccionar rápidamente a nuevas variantes de Ransomware y asegura que los conceptos de protección de IP en Múnich se mantengan frescos a pesar de la carga operativa diaria.

2. Metodología Multimodal y Práctica:

- Simulacros de Phishing: Ejecución mensual de correos trampa. Quienes caigan serán redirigidos a micro-talleres de "reforzamiento inmediato".
- Talleres de Higiene Digital: Sesiones presenciales en plantas de ensamble para el manejo físico de dispositivos y talleres técnicos para ingenieros sobre el uso seguro de Oracle y DB2.
- Contenido Audiovisual: Videos cortos y dinámicos sobre los riesgos de instalar software no autorizado (como *Warzone* o *AnyDesk*).



3. Gamificación y Refuerzo Positivo:

- Concursos por Departamento: Competencias de trivias de seguridad donde los equipos ganadores obtendrán reconocimientos simbólicos y trofeos digitales de "Área Segura".

4. Incentivos en Especie:

Para evitar reportes falsos motivados por dinero, se premiará a quien reporte incidentes reales y detallados con:

- Boleto para eventos culturales o deportivos.
- Bonos en vales de despensa extraordinarios.
- Reconocimiento público como "Defensor del Cuatrimestre".

5. Monitoreo y Control:

- El progreso se medirá a través del LMS (Learning Management System) y se cruzará con las alertas de Splunk. Si un área muestra reincidencia en descargas prohibidas, se activará una sesión de concientización presencial de emergencia.



Conclusión

La finalización de este plan de seguridad integral demuestra que la ciberseguridad efectiva no depende exclusivamente de la implementación de herramientas técnicas avanzadas, sino de una armonía perfecta entre procesos, tecnología y el factor humano. Al integrar normativas robustas y planes de respuesta a incidentes con una estrategia de gobernanza clara, la organización pasa de un estado de vulnerabilidad reactiva a una postura de defensa proactiva y madura. A lo largo de este proyecto, se ha establecido que la protección de los diseños "premium" y la integridad de los sistemas de manufactura son pilares fundamentales para el valor de la marca. La transición de una cultura de seguridad apática hacia una de responsabilidad compartida —reforzada por programas de concientización cuatrimestrales y una estructura jerárquica de responsabilidades— garantiza que los controles implementados sean sostenibles en el tiempo. Finalmente, la adopción del ciclo de mejora continua asegura que la empresa no solo esté protegida contra las amenazas actuales, sino que posea la capacidad adaptativa necesaria para enfrentar los desafíos tecnológicos del mañana, posicionando a la ciberseguridad como un activo estratégico y no simplemente como un centro de costos.

Referencias Bibliográficas.

Estándares y Marcos de Trabajo Internacionales:

- ISACA. (2018). *COBIT 2019 Framework: Introduction and Methodology*. ISACA.
- International Organization for Standardization. (2022). *Information security, cybersecurity and privacy protection — Information security management systems — Requirements* (ISO/IEC Standard No. 27001). <https://www.iso.org/standard/27001>
- International Organization for Standardization. (2020). *Information technology — Security techniques — Evaluation criteria for IT security* (ISO/IEC Standard No. 15408). <https://www.iso.org/standard/72822.html>
- National Institute of Standards and Technology. (2018). *Framework for Improving Critical Infrastructure Cybersecurity, Version 1.1*. U.S. Department of Commerce. <https://doi.org/10.6028/NIST.CSWP.04162018>
- European Parliament and Council of the European Union. (2016). *General Data Protection Regulation (GDPR)*. Regulation (EU) 2016/679.

Materiales de la Universidad Autónoma de Guadalajara (UAG):

- UAG. (2025). *Capítulo 1: Conceptos fundamentales de seguridad*. Material de lectura de la Maestría en Ciberseguridad.
- UAG. (2025). *Capítulo 4: Gestión de riesgos y marcos de gobierno*. Material de lectura de la Maestría en Ciberseguridad.
- UAG. (2025). *Capítulo 5: Aspectos legales y ética en la seguridad*. Material de lectura de la Maestría en Ciberseguridad.
- UAG. (2025). *Capítulo 7: Continuidad de negocio y recuperación ante desastres*. Material de lectura de la Maestría en Ciberseguridad.
- UAG. (2025). *U1AI. Primer avance de proyecto integrador: Identificación de conceptos de seguridad*. Caso de estudio: Empresa de desarrollo de software y hardware automotriz.